

Manual 50 — Mapa cruzado global de gobernanza de IA

Fuente de publicación: edición controlada es-419

Línea base de vigencia: 1 de septiembre de 2026

Propósito

Este manual ofrece un mapa práctico entre la Ley de IA de la UE, ISO/IEC 42001, NIST AI RMF 1.0 y AI 600-1, los marcos de gobernanza de IA de Singapur y AI Verify, los Principios de IA de la OCDE y la Fundación Universal de Gobernanza de IA del repositorio. Está diseñado para implementación, preparación de auditorías, reutilización de evidencia, capacitación y gobierno ejecutivo. No afirma que los distintos regímenes sean legal o técnicamente equivalentes.

Regla principal: armonizar controles sin borrar las diferencias

Un control empresarial común puede respaldar varios regímenes, pero cada fuente conserva su propio alcance, estado normativo, definiciones de actores, umbrales, método de aseguramiento, expectativas documentales y requisitos de evidencia. La ley vinculante controla el mapeo jurídico. Los estándares y marcos voluntarios siguen siendo voluntarios salvo incorporación por ley, contrato o compromiso interno. La certificación ISO, la evaluación de conformidad de la UE, las pruebas AI Verify, el TEVV alineado con NIST y la auditoría interna son mecanismos distintos.

Taxonomía de relaciones

- ****Directa:**** aborda materialmente el mismo objetivo de control al nivel pertinente.
- ****Parcial:**** cubre solo parte del objetivo; requiere evidencia adicional.
- ****De apoyo:**** habilita el objetivo, pero no es suficiente por sí sola.
- ****Contextual:**** informa la intención de gobierno o principios sin crear el mismo requisito.
- ****Ninguna / N/A:**** no existe una relación defendible para el alcance evaluado.

Es preferible un mapeo en blanco o calificado antes que una equivalencia sin sustento.

Veinte objetivos de control comunes

GC-01 Gobierno y rendición de cuentas

Establecer responsables, derechos de decisión, políticas, escalamiento, excepciones y supervisión de la dirección. Evidencia típica: estatuto de gobierno, RACI, aprobaciones de política, decisiones de comité e informes de gestión.

GC-02 Inventario y propiedad de IA

Mantener un inventario vigente de sistemas y casos de uso de IA con propietario, propósito, modelo/proveedor, estado de ciclo de vida, geografía, sensibilidad de datos, dependencias y nivel de riesgo.

GC-03 Responsabilidad por rol y cadena de valor

Determinar quién diseña, provee, despliega, importa, distribuye, integra, opera o modifica materialmente la IA. Conservar las definiciones legales de actores de la Ley de IA de la UE.

GC-04 Clasificación y nivel de riesgo

Aplicar la clasificación exigida por la fuente pertinente y mantener un nivel interno de riesgo para determinar la profundidad del gobierno. No confundir clasificación legal de la UE, niveles internos, evaluación contextual NIST y evaluación de Singapur.

GC-05 Evaluación de riesgo e impacto

Identificar propósito, contexto, personas afectadas, beneficios, daños, uso indebido previsible, dependencias, controles, riesgo residual y decisión responsable antes del despliegue y después de cambios materiales.

GC-06 Gobierno de datos y privacidad

Gobernar procedencia, calidad, derechos, acceso, minimización, linaje, retención, datos sensibles, fuentes RAG y riesgos de datos. Las bases legales y derechos de privacidad siguen siendo específicos de cada jurisdicción.

GC-07 Seguridad, robustez y resiliencia

Proteger modelos, aplicaciones, infraestructura, agentes, datos, herramientas y dependencias frente a amenazas, fallas, abuso y compromiso de la cadena de suministro. Definir recuperación y contención proporcionales al riesgo.

GC-08 Transparencia y comunicación

Proporcionar información precisa sobre uso de IA, capacidades, limitaciones, resultados materiales y responsabilidades al público pertinente. Las obligaciones legales de divulgación siguen siendo específicas de la fuente.

GC-09 Supervisión e intervención humana

Asegurar que las personas tengan competencia, autoridad, información y medios prácticos para intervenir en puntos significativos de decisión o acción. Conservar evidencia de aprobación, anulación, rechazo y escalamiento.

GC-10 Pruebas, evaluación, verificación y validación

Definir afirmaciones y criterios de aceptación; probar desempeño, seguridad, privacidad, robustez y efectividad de controles con evidencia reproducible proporcional al riesgo.

GC-11 Documentación y registros

Mantener registros técnicos y de gobierno vigentes sobre diseño, versiones, decisiones, controles, evaluaciones, aprobaciones, incidentes y cambios materiales.

GC-12 Puertas de despliegue y aprobación

Exigir una decisión responsable antes de producción o expansión material: aprobar, aprobar con condiciones, restringir, remediar, suspender o rechazar.

GC-13 Gobierno de terceros y cadena de suministro

Evaluar proveedores, modelos, herramientas, APIs, procesadores, hosting y dependencias de agentes. Cubrir datos, seguridad, cambios, incidentes, continuidad, concentración y salida.

GC-14 Monitoreo y aseguramiento continuo

Monitorear desempeño, deriva, indicadores de riesgo, denegaciones de política, quejas, incidentes, cambios de proveedor/modelo, hallazgos abiertos y efectividad de controles.

GC-15 Gestión de incidentes

Detectar, contener, investigar, preservar evidencia, remediar y escalar incidentes de IA. Umbrales y plazos de notificación externa siguen siendo jurisdiccionales.

GC-16 Gestión de cambios y revalidación

Tratar cambios de modelo/proveedor, datos/RAG, propósito, población afectada, herramientas/APIs, autonomía, permisos, geografía o controles como posibles disparadores de revalidación.

GC-17 Auditoría y aseguramiento independiente

Aplicar desafío independiente proporcional a la materialidad y conservar hallazgos, respuestas de gestión, evidencia de remediación y cierre.

GC-18 Alfabetización y competencia en IA

Asegurar competencias apropiadas para personal de gobierno, desarrollo, despliegue, supervisión, seguridad, compras, legal, auditoría y operaciones.

GC-19 Mejora continua

Usar monitoreo, incidentes, pruebas, auditoría, retroalimentación, cambios regulatorios y del proveedor para mejorar controles y gobierno.

GC-20 Identidad del agente, autonomía, permisos y procedencia de acciones

Asignar identidades atribuibles, limitar autonomía, aplicar mínimo privilegio, restringir herramientas y datos, exigir puntos humanos significativos cuando corresponda, conservar procedencia de acciones, monitorear y contener.

Guía por familia de fuentes

Ley de IA de la UE

Tratarla como ley vinculante dentro de su alcance. Mantener explícitos roles legales, categorías de sistemas, prácticas prohibidas, fechas de aplicación, transparencia, obligaciones de alto riesgo y GPAI, conformidad, registro, monitoreo posterior al mercado, incidentes y aplicación cuando correspondan. Un control empresarial genérico es evidencia de apoyo salvo que también se demuestre el requisito legal exacto.

ISO/IEC 42001

Tratarla como estándar de sistema de gestión de IA. Mapear a alto nivel mediante objetivos de gestión y control redactados de forma independiente; no reproducir texto protegido. Alineación no equivale a certificación y certificación no sustituye cumplimiento legal.

NIST AI RMF 1.0 y AI 600-1

Relacionar controles con GOVERN, MAP, MEASURE y MANAGE, y con acciones específicas para GenAI cuando corresponda. NIST sigue siendo guía voluntaria y no debe presentarse como ley o certificación.

Singapur y AI Verify

Usar la familia Model AI Governance Framework, orientación GenAI, AI Verify y gobernanza de IA agéntica como referencias prácticas de gobierno y aseguramiento. Las pruebas AI Verify no son certificación automática ni prueba de cumplimiento en otra jurisdicción.

Principios de IA de la OCDE

Usarlos como línea base intergubernamental para crecimiento inclusivo y bienestar, derechos humanos y valores democráticos, transparencia y explicabilidad, robustez/seguridad y rendición de cuentas. No sustituyen la ley jurisdiccional.

Registro de evidencia armonizada

El conjunto mínimo reutilizable incluye: inventario de IA; estatuto y RACI; evaluación de riesgo/impacto; linaje de datos/RAG; arquitectura de seguridad; artefactos de transparencia; diseño de supervisión humana; paquete TEVV; aprobación de despliegue; evaluación de terceros; monitoreo; incidente; cambio/revalidación; auditoría independiente; capacitación; backlog de mejora; y procedencia de acciones de agentes.

Para cada evidencia reutilizada registrar: evidencia → control de origen → relación con la fuente destino → suficiencia y limitaciones → evidencia adicional específica → responsable → fecha/versión.

Escenarios prácticos

Asistente GenAI empresarial

Exige inventario, evaluación de proveedor, linaje RAG, riesgo, arquitectura de seguridad, pruebas, transparencia, aprobación, monitoreo e incidentes. El análisis UE determina además rol legal y obligaciones aplicables; NIST AI 600-1 profundiza riesgos GenAI; Singapur apoya gobierno y pruebas; ISO/IEC 42001 aporta sistema de gestión; OCDE aporta objetivos de rendición de cuentas, transparencia y robustez.

IA para contratación

Combinar análisis jurídico y de derechos, sesgo/equidad, supervisión humana, documentación, monitoreo, apelación/escalamiento y cambio. La evaluación común puede reutilizarse, pero la clasificación UE y obligaciones locales requieren análisis separado.

Flujo agéntico con acceso a herramientas

Añadir identidad del agente, mínimo privilegio, listas permitidas, límites de acción, aprobaciones, registros de procedencia, contención y pruebas de abuso.

Cambio de modelo del proveedor

Detectar el cambio, evaluar materialidad, repetir pruebas pertinentes, actualizar riesgo/transparencia y emitir nueva decisión de despliegue cuando corresponda.

Aseguramiento multirrégimen

Un paquete TEVV puede respaldar varias fuentes solo si se documentan relación, alcance, suficiencia, limitaciones y evidencia adicional. No convertirlo en porcentaje universal de cumplimiento.

Método de análisis de brechas

Para cada control: identificar control implementado; determinar fuentes aplicables; asignar tipo de relación; identificar faltantes específicos; clasificar la brecha como control, evidencia, interpretación legal, proceso, aseguramiento o competencia; priorizar P1/P2/P3; asignar responsable y fecha; volver a probar y actualizar la justificación.

Reglas contra falsa equivalencia

No publicar porcentajes universales de cumplimiento entre regímenes distintos. No afirmar que certificación ISO prueba cumplimiento de la Ley de IA de la UE, que adoptar NIST equivale a cumplimiento legal o que AI Verify equivale a certificación en otra jurisdicción. Conservar la incertidumbre y obtener interpretación jurídica calificada cuando se requiera una conclusión legal.

Control de vigencia

Antes de cada versión controlada, revalidar la línea legal de la Ley de IA de la UE, edición/estado de ISO/IEC 42001, estado de NIST AI RMF y AI 600-1, versiones vigentes de Singapur y estado de los Principios de IA de la OCDE.

Criterio de finalización

El manual está completo cuando cada conclusión del mapa es trazable a una familia de fuente, tipo de relación, objetivo común, clase de evidencia reutilizable, nota de diferencia y brecha específica. El objetivo es reutilización defendible de gobierno, no equivalencia artificial.